

A FIELD TOOL FOR ENGINEERING LEADERS

The AI Code Assurance Checklist

Eight questions an auditor will ask about your AI-assisted delivery, and what a defensible answer sounds like.

Alex Bunardzic

For CTOs and engineering leaders in fintech, healthtech, insurance, and other regulated environments.

Nobody asks whether your code is sound. They ask whether you can show it.

A director of engineering I know spent a Tuesday morning in a conference room with an external assessor who had one page of notes and no curiosity about her roadmap. Forty minutes in, he asked who had reviewed the payment-path changes shipped in March. She had an answer ready. Assembling the evidence behind it took her eleven days.

Nothing was broken. No incident, no breach, no finding. That is the part organizations tend to miss about assurance — you can be entirely sound and still unable to demonstrate it, and from where the assessor sits both conditions read the same.

Review rested for decades on an assumption so ordinary nobody bothered to name it: every line had an author, and the author could be asked why. That premise no longer holds. Much of what ships now was assembled by a model that cannot be asked anything, and the name on the commit may have looked at it for eleven seconds. Syntactically perfect, lint-clean, passing its own tests — and carrying a kind of defect no experienced hand would have introduced.

The pace is not the exposure. The exposure is that the pace arrived without the paper trail that used to travel alongside it, unbidden and unbilled.

What this list is

Eight questions, drawn from what assessors, regulators, acquirers, and newly appointed board members actually ask once AI enters a delivery pipeline. For each one: why it lands badly now, what a defensible answer sounds like, and what sinks an answer that seemed fine in the room.

These are guidelines, not rules. A small internal tool holding no regulated data can reasonably skip half of this — as long as you skipped it on purpose, having looked, rather than because nobody looked. That distinction is the whole exercise.

What this list is not

- Not a compliance scorecard. A percentage here would be theatre, and theatre is the condition this exists to catch.
- Not an audit. It is the conversation you have before deciding whether one is warranted.
- Not vendor guidance. No product on the market answers any of these eight questions for you.

Run it on yourself before anyone runs it on you. Ninety minutes with your leads and a whiteboard covers all eight. If most answers come back promptly and with evidence behind them, close the document and get on with your quarter — a legitimate outcome, and the one I would rather you reach.

01 "How much of this was written by AI, and how do you know?"**WHY IT LANDS BADLY**

Almost nobody measures provenance. Adoption happened bottom-up, one licence after another, and by the moment anyone thought to ask, the candid answer was a shrug. A shrug is survivable in a retro and fatal in an assessment, because it tells the assessor that every subsequent answer is also unmeasured.

A DEFENSIBLE ANSWER

A figure with a method behind it, plus a boundary: where assistance is permitted, where it is prohibited by policy, and how that boundary is enforced rather than merely announced. "Roughly 60% outside the regulated paths, and almost nothing inside them, and here is the control that holds that line."

WHAT SINKS IT

A number nobody can source. Assessors probe estimates, and an estimate that collapses under one follow-up damages you more than conceding you do not measure it yet.

02 "Who approved this change, and what did they verify?"**WHY IT LANDS BADLY**

Approval survived the transition. Verification often did not. When generated diffs arrive at many multiples of the previous volume, review degrades into acknowledgement — the approval log looks unchanged while the scrutiny behind each entry has thinned to nothing.

A DEFENSIBLE ANSWER

A named human accountable for each merged change, and a description of what that human examined that goes beyond "the diff." Behavior confirmed, edge conditions considered, assumptions questioned. Accountability that sits with somebody who can be asked why.

WHAT SINKS IT

"The model generated it and the pipeline was green." You cannot delegate accountability to a model, and an assessor recognizes the attempt immediately.

03 "Your tests pass. What would they catch?"**WHY IT LANDS BADLY**

This is the sharpest question on the list, and the one most likely to be answered with a coverage percentage — which measures execution, not verification. When a model authors both the implementation and the tests around it, the tests tend to confirm what was generated rather than challenge it. The Guild calls this 'test theatre'. Coverage climbs, assurance does not.

A DEFENSIBLE ANSWER

Evidence that the suite fails when behavior breaks. Mutation testing is the honest instrument here: damage the logic on purpose and observe whether anything turns red. A suite that holds green against injected faults is decoration, and you would rather learn that from your own run than from someone holding a clipboard.

WHAT SINKS IT

Citing coverage as though it answered the question. It answers a different one, and everybody in the room knows it.

04 "Does every dependency here exist, and did somebody choose it?"**WHY IT LANDS BADLY**

Models invent packages. They also pull in abandoned ones, typo-squatted ones, and ones whose licence terms nobody examined. Each arrives inside a diff that otherwise looks entirely routine, and each is yours the moment it merges.

A DEFENSIBLE ANSWER

A bill of materials that includes what the assistant introduced, plus verification that suggested packages are genuine, maintained, and licence-compatible with commercial distribution. Somebody chose each one, and can be named.

WHAT SINKS IT

"It resolved and the build succeeded." Phantom and hostile dependencies both resolve beautifully. That is precisely why they are dangerous.

05 "What is your agent permitted to touch?"**WHY IT LANDS BADLY**

Agents accumulate access as service accounts always have, only quicker. They often borrow a human session, inherit admin scope nobody audited, and hold credentials that never expire. The inventory of what they may touch frequently exists nowhere, which is itself the finding.

A DEFENSIBLE ANSWER

Each agent holds its own identity, permissions scoped to the task and bounded in duration, high-consequence actions gated behind authorization, and every action reconstructable after the fact. You can recite the inventory from memory or hand over a file — either proves it exists.

WHAT SINKS IT

Nobody in the room can hand over the inventory, and three colleagues offer three different accounts of what the agent may touch.

06 "Where does regulated data go once an assistant is in the loop?"**WHY IT LANDS BADLY**

This is the question that ends careers in regulated settings, and the one most often answered with policy rather than evidence. A context window is a data destination. So is a log line, a prompt history, and whatever a third-party provider retains under terms somebody accepted on a Thursday afternoon without reading.

A DEFENSIBLE ANSWER

Mapped flows that treat context windows and prompt logs as destinations alongside databases. Over-fetching addressed, sensitive fields absent from logs, retention terms with each provider examined and recorded, and residency obligations satisfied where they apply.

WHAT SINKS IT

"We instructed everyone not to paste customer data into it." An instruction is not a control, and an assessor will ask what happens when somebody ignores it.

07 "When did somebody independent last examine this, and what did they find?"**WHY IT LANDS BADLY**

Internal review carries a stake in the outcome. So does a dashboard sold by the vendor whose coverage it reports on — that is a supplier's assurance about its own merchandise, which is a marketing artifact wearing the costume of evidence. Assessors discount both, quickly.

A DEFENSIBLE ANSWER

A dated review by somebody outside the build, written findings with owners and remediation priority attached, and a cadence tied to delivery rhythm rather than the calendar. Re-examined after each heavy AI-assisted sprint, not each September.

WHAT SINKS IT

A green dashboard offered as the answer. Security you cannot independently verify is not security — it is a promise from a party with an interest in your comfort.

08 "When this fails at three in the morning, what happens?"**WHY IT LANDS BADLY**

Generated implementations lean toward the happy path, because that is the path described in the prompt. Failure handling is where models are thinnest and reviewers least attentive. Errors get swallowed rather than surfaced, and the incident that follows is diagnosed slowly by colleagues reading logic nobody in the building composed.

A DEFENSIBLE ANSWER

Degradation that is graceful and deliberate, failures that surface rather than vanish, a rollback path somebody has exercised recently, and an incident process that distinguishes operator error from agent error from structural weakness. Those three demand different remedies, and conflating them guarantees the next occurrence.

WHAT SINKS IT

"We would roll back." Asked when rollback was last rehearsed, the room falls silent.

A note on order. Questions three, six, and seven carry the most weight in regulated settings, and they are also the three most often answered with a number, a policy, or a dashboard rather than with evidence. If your ninety minutes runs short, spend it there.

Score it honestly. The whole benefit is in the honesty.

For each question, tick one column. **Evidence:** you could hand somebody the proof this week. **Reconstruct:** the answer exists, but lives in somebody's head and would take days to assemble. **Cannot:** exactly that.

QUESTION	EVIDENCE 2	RECONSTRUCT 1	CANNOT 0
1. Proportion authored by AI, and the method behind the figure	☐	☐	☐
2. Named accountability per change, and what was verified	☐	☐	☐
3. Proof the suite fails when behavior breaks	☐	☐	☐
4. Bill of materials covering assistant-introduced packages	☐	☐	☐
5. The inventory of what each agent may touch	☐	☐	☐
6. Regulated-data flows including context windows and prompt logs	☐	☐	☐
7. Dated independent review with written findings	☐	☐	☐
8. Rehearsed failure and rollback path	☐	☐	☐

Reading the total

13–16

You are in sound order.

Close this document. Your exposure is ordinary and your evidence is assembled. Anyone selling you an assessment on these grounds is selling you something you already own.

7–12

The answers exist, but only in people's heads.

The common band, and the uncomfortable one. You are probably sound and definitely undemonstrable, which means an assessment arriving on someone else's schedule will consume weeks you had allocated elsewhere. Convert a couple of answers into evidence each quarter and this resolves itself without drama.

0–6

The next formal request will land badly.

Not because anything is necessarily broken, but because you have no way to demonstrate otherwise, and an assessor's default reading of silence is unfavourable. Treat any tick in the third column on questions three, six, or seven as the place to begin.

A low total is not evidence of negligence. It is evidence that adoption outran documentation, which describes nearly every organization that moved early. The distinction that matters to an assessor is whether you knew that before they told you.

Three steps, thirty days, no outside help required.

Each is inexpensive, and each converts one unanswerable question into an answerable one. Do them in order.

STEP ONE · WEEK ONE

Pick your highest-consequence path and answer question one for that path alone.

Not the whole estate. One path — payments, patient records, trading, whatever would appear in the headline. Establish where assistance is permitted along it, where it is not, and what enforces the boundary. Scoping to one path is what converts this from a quarter of labour into an afternoon.

STEP TWO · WEEK TWO

Run mutation testing against one critical module.

Damage the logic on purpose and observe whether the suite objects. One module, one afternoon. The result is either reassuring or the most valuable finding you will encounter this quarter, and both outcomes justify the afternoon. It is the plainest instrument here for turning a belief into evidence.

STEP THREE · WEEKS THREE AND FOUR

Assemble the agent permission inventory.

Just the inventory. Every agent operating against your systems, its identity, what it may reach, and who granted that. Most organizations discover during this exercise that the inventory is shorter than feared and the permissions broader than anyone assumed. Both discoveries repay the exercise, and neither requires a consultant.

An organization that cannot demonstrate its own soundness is not sound. It is fortunate, and fortune is not a control.

If the exercise leaves you unsettled rather than reassured, that unease is information. A short, independent assessment answers whether it is warranted — and the ideal outcome of such an assessment is discovering you did not require one. I would rather tell you that in an hour than bill you for confirming it over six weeks.

Which of the eight would you least want asked on Monday? Start there.

Alex Bunardzic · alexbunardzic.com · alexbunardzic@gmail.com

Sources and credit. The technical substance behind questions three through eight draws on the open, vendor-neutral checklists published by the **AI Craftspeople Guild** — the AI Code Audit Checklist, the AI Security Baseline Checklist, the AI Code Optimization Checklist, and the AI Code Diagnostic Checklist — which in turn draw on OWASP's LLM and Agentic Top 10, SAFE-MCP, and the NIST AI Agent Standards Initiative. Those checklists go deeper on the engineering detail than this document does, they are free, and they sell nothing: aicraftspeopleguild.github.io.

The form of this document — an unofficial checklist meant for argument rather than compliance — follows Henrik Kniberg's *unofficial Scrum Checklist*, reused in the spirit in which he shared it.

This document reflects one practitioner's view of what assessors ask and what satisfies them. It is not legal advice, not a regulatory standard, and not a guarantee of any audit outcome. Version 1.0 · 2026.